

**Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»**

Дисциплина
«Информационная безопасность»

Лабораторная работа №1
Разработка защищенного REST API с интеграцией в CI/CD

Выполнил: Малышев Никита Александрович
Группа: P3412

2026 год

Ссылка на публичный репозиторий с кодом проекта

<https://github.com/nktmlshv/infosec-lab1>

О проекте

- Spring Boot API
- JWT-аутентификация
- PostgreSQL
- защищённый набор эндпоинтов для работы с данными и профилем
- CI/CD с SAST и SCA

API

1. Авторизация

- POST /auth/login
- вход: username, password
- ответ: JWT token + expiration

```
curl -X POST http://localhost:8080/auth/login \  
-H "Content-Type: application/json" \  
-d '{  
    "username": "admin",  
    "password": "StrongAdminPassword123!"  
}'
```

2. Получение данных

- GET /api/data
- требует JWT
- возвращает список постов

```
curl -X GET http://localhost:8080/api/data \  
-H "Authorization: Bearer <JWT_TOKEN>"
```

3. Профиль текущего пользователя

- GET /api/profile
- требует JWT
- возвращает username + message

```
curl -X GET http://localhost:8080/api/profile \  
-H "Authorization: Bearer <JWT_TOKEN>"
```

Меры защиты

Аутентификация и авторизация

- SecurityConfig
- permitAll() только для /auth/login и /error
- все остальные маршруты: authenticated()
- BCryptPasswordEncoder
- JWT filter: проверка Authorization: Bearer ...

- `JwtAuthenticationFilter`: в каждом запросе
 - извлекает токен
 - валидирует подпись и срок жизни
 - загружает пользователя по `username`
 - кладёт `authentication` в `SecurityContextHolder`
- `JwtUtil`
 - обязательная проверка `jwt.secret`
 - минимальная длина секрета: 32 символа
 - HS256
 - `expiration` в ms

Защита от SQL Injection

- основная работа с БД через Spring Data JPA / Hibernate
- репозитории без raw SQL
- все запросы идут через параметризованные JPA-методы
- `UserRepository.findByUsername(...)`
- `PostRepository.findAllByOrderByCreatedAtDesc()`
- нет конкатенации пользовательского ввода в SQL строку

Защита от XSS

- `HtmlSanitizer`
- `StringEscapeUtils.escapeHtml4(...)`
- HTML-экранирование перед возвратом данных в ответ
- применено к `username`, `title`, `content`, `author`

Скриншоты отчётов

```
<FindBugsSummary num_packages='10' total_classes='15' total_size='291' clock_seconds='1.28' referenced_classes='174' vm_version='23.0.1+11-3'>
  <FileStats path='com/example/securitylab/SecurityLabApplication.java' size='6' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/config/SecurityConfig.java' size='19' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/controller/DataController.java' size='31' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/dto/AuthRequest.java' size='10' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/dto/AuthResponse.java' size='12' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/dto/DataPayload.java' size='16' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/entity/Post.java' size='51' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/entity/User.java' size='35' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/repository/PostRepository.java' size='2' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/repository/UserRepository.java' size='3' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/security/JwtAuthenticationFilter.java' size='21' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/security/JwtUtil.java' size='37' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/service/UserDetailsServiceImpl.java' size='15' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/startup/DataInitializer.java' size='25' bugCount='0'></FileStats>
  <FileStats path='com/example/securitylab/util/HtmlSanitizer.java' size='8' bugCount='0'></FileStats>
  <PackageStats package='com.example.securitylab' total_bugs='0' total_size='6' total_types='1'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.config' total_bugs='0' total_size='19' total_types='1'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.controller' total_bugs='0' total_size='31' total_types='1'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.dto' total_bugs='0' total_size='38' total_types='3'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.entity' total_bugs='0' total_size='86' total_types='2'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.repository' total_bugs='0' total_size='5' total_types='2'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.security' total_bugs='0' total_size='58' total_types='2'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.service' total_bugs='0' total_size='15' total_types='1'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.startup' total_bugs='0' total_size='25' total_types='1'>--
  </PackageStats>
  <PackageStats package='com.example.securitylab.util' total_bugs='0' total_size='8' total_types='1'>--
  </PackageStats>
  <FindBugsProfile>--
  </FindBugsProfile>
</FindBugsSummary>
<ClassFeatures></ClassFeatures>
<History></History>
</BugCollection>
```

Рис. 1. SpotBugs report



Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | Getting Help: [github issues](#)

♥ [Sponsor](#)

Project: securitylab

com.example:securitylab:0.0.1-SNAPSHOT

Scan Information ([show all](#)):

- *dependency-check version:* 12.1.0
- *Report Generated On:* Wed, 30 Sep 2026 07:22:23 +0300
- *Dependencies Scanned:* 88 (51 unique)
- *Vulnerable Dependencies:* 0
- *Vulnerabilities Found:* 0
- *Vulnerabilities Suppressed:* 0
- ...

Summary

Display: [Showing Vulnerable Dependencies \(click to show all\)](#)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
------------	-------------------	---------	------------------	-----------	------------	----------------

Dependencies (vulnerable)

This report contains data retrieved from the [National Vulnerability Database](#).

This report may contain data retrieved from the [CISA Known Exploited Vulnerability Catalog](#).

This report may contain data retrieved from the [Github Advisory Database \(via NPM Audit API\)](#).

This report may contain data retrieved from [RetireJS](#).

This report may contain data retrieved from the [Sonatype OSS Index](#).

Рис. 2. Dependency Check report

Ссылка на последний успешный запуск pipeline

<https://github.com/nktmlshv/infosec-lab1/actions/runs/36674824973>